

Musterlösung und Bewertungsraster

Übungsklausur Variante A

BCSM 402 - Business Continuity Management

Sommersemester 2026 | Gesamt: 120 Punkte

Abschnitt 1	40 Punkte
Abschnitt 2	40 Punkte
Abschnitt 3	40 Punkte

Bewertungshinweis: Sinngemäß richtige Antworten sind zu akzeptieren, sofern sie fachlich nachvollziehbar begründet sind. Bei frei zu setzenden BIA-Werten zählt insbesondere die Konsistenz der Beziehungen $RTO \leq MTPD$ und die Begründung.

Prüfungsabschnitt 1 - Lösungsschlüssel

20 Single-Choice-Fragen (je 2 Punkte)

Nr.	Lösung	Punkte	Kurzbegründung
1	a	2	Scope wird organisatorisch, geografisch/physisch und logisch/Wertschöpfung abgegrenzt.
2	b	2	Ausschlüsse müssen nachvollziehbar begründet sein und dürfen kritische Funktionen nicht gefährden.
3	c	2	ISO 22301 enthält Muss-Anforderungen und ist zertifizierbar; BSI 200-4 liefert Methodik und Stufenmodell.
4	b	2	Das Reaktiv-BCMS dient dem schnellen Aufbau einer grundlegenden Reaktionsfähigkeit.
5	a	2	Die Gesamtverantwortung des Top-Managements ist nicht delegierbar.
6	b	2	Der BCB steuert Methodik und Vorsorge, berichtet direkt und leitet nicht zwingend den Krisenstab.
7	b	2	A = Accountable.
8	a	2	Golden Rule: nur ein A pro Aufgabe.
9	b	2	BIA fragt nach Auswirkungen; Risikoanalyse nach Ursachen und Wahrscheinlichkeiten.
10	a	2	Der Wiederanlauf muss vor Erreichen der maximal tolerierbaren Ausfallzeit liegen.
11	b	2	RPO ist der höchsttolerierbare Datenverlust.
12	c	2	MBCO ist das minimale Fortführungs-/Notbetriebsniveau.
13	a	2	Die Reihenfolge entspricht Identifikation, Analyse, Evaluation und Behandlung.
14	a	2	Die vier üblichen Optionen sind vermeiden, vermindern, übertragen und akzeptieren.
15	b	2	Die Folien ordnen BIA=Was, Strategie=Wie und BCP=Wer/Wann zu.
16	a	2	Beim Notfall greifen Pläne; bei der Krise fehlen sie oder greifen nicht ausreichend.
17	b	2	FOR-DEC: Facts, Options, Risks & Benefits, Decision, Execution, Check.
18	b	2	Stage I prüft Dokumentation und grundsätzliche Eignung.
19	a	2	Eine Nichtkonformität braucht Anforderung, Abweichung und objektiven Nachweis.
20	b	2	ITSCM sichert die technische Seite der Kontinuität.

Maximal: 40 Punkte.

Aufgabe 2 - Dokumentenhierarchie eines BCMS (8 Punkte)

Musterantwort

- Plan: BCM-Leitlinie/Policy, Scope-Dokument, Rollen- und Verantwortlichkeitsmatrix (z.B. RASCI), Trainings- und Awareness-Konzept.
- Do: BIA-Methode und BIA-Bericht, Risikoanalyse, BC-Strategie, Notfallhandbuch/Notfallpläne, Wiederanlauf- und Wiederherstellungspläne.
- Check: Test- und Übungsplan, Testprotokoll/Übungsbericht, interne Auditberichte und Kennzahlen.
- Act: Maßnahmen-/Verbesserungsplan, Korrekturmaßnahmen, Management-Review-Protokoll und Nachverfolgung.

Bewertungsraster

Kriterium	Punkte
Mindestens zwei passende Plan-Dokumente	2
Mindestens drei passende Do-Dokumente	3
Mindestens ein Check-Dokument	1
Mindestens ein Act-Dokument	1
Schlüssige Hierarchie/PDCA-Zuordnung	1

Fundstelle: Kapitel 1 (Strukturelemente/Dokumentation), Kapitel 2 (PDCA/ISO 22301), Übungen 1-5.

Aufgabe 3 - Stufenmodell des BSI 200-4 (8 Punkte)

Musterantwort

- Reaktiv-BCMS: schneller Einstieg, rudimentäre Reaktionsfähigkeit, vereinfachte Methodik, Fokus auf BAO, Alarmierung und Sofortmaßnahmen.
- Aufbau-BCMS: Absicherung der wichtigsten zeitkritischen Prozesse und Ressourcen, vollständige BIA und Risikoanalyse, aber eingeschränkter Prozessumfang.
- Standard-BCMS: vollständiger Umfang und vollständige Methodik, gesamter PDCA-Zyklus, kontinuierliche Verbesserung; auf ISO-22301-Konformität und Zertifizierung ausrichtbar.
- BSI 200-4 selbst ist keine ISO-Zertifizierung; zertifiziert wird nach ISO 22301.

Bewertungsraster

Kriterium	Punkte
Reaktiv: Ziel und Fokus	2
Aufbau: Ziel, Methodik und Umfang	2
Standard: Vollständigkeit/PDCA	2
Korrekte Aussage zur Zertifizierung	2

Fundstelle: Kapitel 2, Folien zum Stufenmodell des BSI 200-4.

Aufgabe 4 - BIA und kritische Parameter (8 Punkte)

Musterantwort

- BIA: untersucht die Schäden/Auswirkungen eines Prozess- oder Ressourcenausfalls im Zeitverlauf und bestimmt Kritikalität, Wiederanlaufanforderungen und Ressourcenbedarf.
- Risikoanalyse: untersucht Ursachen, Gefährdungen, Schwachstellen und Eintrittswahrscheinlichkeiten.
- MTPD: Zeitpunkt/Dauer, nach der ein Ausfall nicht mehr tolerierbar ist und die Überlebensfähigkeit gefährdet.
- RTO: Zeit nach dem Ereignis, innerhalb der der Notbetrieb aufgenommen werden soll; RTO muss kleiner oder gleich MTPD sein.
- RPO: maximal zulässiger Datenverlust bzw. zeitlicher Abstand zum letzten wiederherstellbaren Datenstand.
- MBCO: minimales Leistungs-/Kapazitätsniveau des Notbetriebs.

Bewertungsraster

Kriterium	Punkte
BIA korrekt abgegrenzt	2
Risikoanalyse korrekt abgegrenzt	1
MTPD und RTO	2
RPO	1
MBCO	1
Beziehung $RTO \leq MTPD$	1

Fundstelle: Kapitel 4 (BIA vs. Risikoanalyse, Definitionen), Kapitel 1 (kritische Parameter).

Aufgabe 5 - BCM-Governance und RASCI (8 Punkte)

Musterantwort

- Institutionsleitung: nicht delegierbare Gesamtverantwortung, Freigabe der BCM-Leitlinie, Bereitstellung von Budget, Zeit und Personal, Zuweisung und Kommunikation von Rollen.
- BCB: zentrale Ansprechperson, Konzeption/Planung/Steuerung des BCMS, Methodenvorgaben, BIA/Risiken, Tests, Reporting; möglichst direkte Berichtslinie zur Institutionsleitung.
- Dezentrale BC-Koordinatoren: Umsetzung in den Fachbereichen, Lieferung von Daten, Pflege von Plänen und Eskalation an den BCB.
- RASCI für BCM-Leitlinie: Institutionsleitung = A, BCB = R, Fachbereiche = C/S, Mitarbeitende = I.

Bewertungsraster

Kriterium	Punkte
Institutionsleitung	2
BCB	2
BC-Koordinatoren	2
Plausible RASCI-Zuordnung	2

Fundstelle: Kapitel 3 (Governance, BCB, RASCI), Übung 2.

Aufgabe 6 - Auditarten und Zertifizierungsstufen (8 Punkte)

Musterantwort

- 1st Party: internes Audit im Auftrag des Managements zur Selbstprüfung, Systempflege und Vorbereitung.
- 2nd Party: Prüfung eines Lieferanten/Partners durch eine Partei mit direktem Interesse.
- 3rd Party: unabhängige akkreditierte Zertifizierungsstelle zur ISO-22301-Zertifizierung.
- Stage I: Dokumentation und Theorie; Scope, Richtlinien, Prozesse, BIA/Risikoanalyse, Managementreview, interne Audits und grundsätzliche Eignung.
- Stage II: Praxis und Umsetzung; Interviews, Begehungen, Stichproben und Review von Aufzeichnungen.

Bewertungsraster

Kriterium	Punkte
1st/2nd/3rd Party korrekt	3
Stage I	2
Stage II	2
Auditmethoden	1

Fundstelle: Kapitel 8 (Auditarten, Stage I/II).

Aufgabe 7 - Scope und Business Impact Analyse (20 Punkte)

Musterantwort

- In Scope z.B.: Materialplanung, Einkauf, Produktion/Montage, Qualitätssicherung, Marketing, Produktions-IT. Externe Stakeholder/Abhängigkeiten: BuCa, ACT, IT-4all, Mutterkonzern, Kunden.
- Finanzieller Schaden 4 h: $20.000 \text{ EUR} \times 6 \times 4 = 480.000 \text{ EUR}$. Zwei Produktionstage: $20.000 \text{ EUR} \times 6 \times 8 \times 2 = 1.920.000 \text{ EUR}$.
- Beispielwerte (andere begründete Werte sind möglich): MTPD 8 h, RTO 4 h, RPO 1 h, MBCO 50-70 %. Entscheidend sind $\text{RTO} \leq \text{MTPD}$, nachvollziehbare Abhängigkeiten und ein operativ sinnvolles Mindestniveau.
- Weitere Schäden: persönliche Sicherheit, Verletzung von Gesetzen/Verträgen, Image/Reputation, Nichterfüllung von Aufgaben, Lieferverzug/Vertragsstrafen.

Bewertungsraster

Kriterium	Punkte
Vier In-Scope-Elemente und zwei Stakeholder	6
Berechnung 480.000 EUR	2
Berechnung 1.920.000 EUR	2
Vier Parameter mit plausiblen Werten	6
Konsistenz und Begründung	2
Zwei weitere Schadenskategorien	2

Fundstelle: Übung 1 (Scope), Übung 5 (BIA und Produktionswerte), Kapitel 4.

Aufgabe 8 - Risikobewertung und BC-Strategie (20 Punkte)

Musterantwort

- Zulieferer: Bedrohung Hochwasser; Schwachstelle zwei 50%-Lieferanten ohne weitere Quelle/geringer Lagerbestand; Risiko Materialmangel und Produktionsstillstand; Auswirkungen Umsatzverlust, Lieferverzögerung, Vertragsstrafen und Reputation.
- IT: Bedrohung Systemausfall/Cyberangriff; Schwachstelle veralteter Restore-Test, kein abgestimmter RPO, Abhängigkeit von IT-4all; Risiko Überschreitung der RTO und Stillstand der Montage.
- Risikostufe: beide mindestens hoch, da der Schaden sehr hoch ist; Lieferantenausfall ist bereits eingetreten und deckt 50 % ab, IT-Ausfall kann den gesamten Prozess stoppen.
- Präventiv: zusätzlicher Lieferant, höhere Sicherheitsbestände, duale Standorte, vertragliche RTO/RPO, regelmäßige Restore-Tests, Offline-Backups. Reaktiv: alternative Beschaffung, Priorisierung/gedrosselter Notbetrieb, Aktivierung IT-Wiederanlaufplan, Notfallkommunikation.
- Notfallplan: Zweck/Scope, Aktivierungsschwellen, Rollen/Stellvertretungen, Melde-/Eskalationswege, konkrete Maßnahmen und Prioritäten, Ressourcen/Kontakte, Kommunikation, Rückkehr in Normalbetrieb, Dokumentation.

Bewertungsraster

Kriterium	Punkte
Zulieferer-Risikokette vollständig	4
IT-Risikokette vollständig	4
Risikoeinstufung und Begründung	4
2 präventive + 2 reaktive Maßnahmen	4
Vier Planinhalte	4

Fundstelle: Kapitel 5 (Risikomanagement), Kapitel 6 (Strategien und Pläne), Übungen 6 und 7.